

ScholarBase

Quality Assurance & Security Test Report

Unit • Integration • API E2E • OWASP API Security Top 10 (2023) • UAT

Application	ScholarBase - university question-paper, notes & study-room platform
Stack under test	NestJS 10 + Prisma 5 / PostgreSQL (Neon) / S3-compatible object storage / React 18 + Vite
Test cases executed	148 (Unit 42, Integration 35, E2E+Security 57, UAT 14)
Automated result	77/77 Jest specs passed; 42 passed / 11 failed / 2 warned in the API suite
Defects raised	16 (0 Critical, 1 High, 9 Medium, 6 Low)
Report date	12 August 2026

All results in this report were produced by executing the test suites against a running instance of the application. No result is estimated or inferred. The suites are committed to the repository and can be re-run to reproduce every number (see Appendix A).

1. Executive summary

ScholarBase's **authentication and authorisation core is genuinely solid**. Every privilege-escalation and token-forgery attempt in this engagement failed: admin-only routes rejected student tokens, a JWT forged with the real signing secret claiming `role=ADMIN` was still refused because the role is re-read from the database, and mass-assignment of an admin role at signup was blocked by validation whitelisting. Passwords are argon2-hashed and refresh/reset tokens are stored only as HMACs. That is the hard part of the system, and it is right.

The gaps are concentrated in the **protective layers around** that core rather than in the core itself: there is no rate limiting anywhere, no security headers, CORS is open to every origin, and the forgot-password endpoint leaks account existence through response timing despite deliberately returning a uniform body. None of these require an authenticated attacker.

Release recommendation: fix QA-01 (login brute force) before opening the site to students. With no throttling, an eight-character minimum password and no complexity rule, account takeover by guessing is practical. QA-02 through QA-08 should follow shortly after; the Low items can be scheduled normally.

1.1 Results by phase

Phase	Cases	Passed	Failed	Focus
Unit	42	42	0	Pure logic: durations, MIME allowlist, header sanitisation, DTO validation rules
Integration	35	35	0	Services against mocked Prisma: credential handling, reset-token lifecycle, upload rules
API E2E	18	15	3	Black-box HTTP: auth lifecycle, catalogue reads, presigned URL issuance
Security (OWASP)	39	27	10	API1-API10 probes against the running server
UAT	14	11	3	Browser-driven end-user journeys, responsive and theme checks

The three E2E failures are environmental, not defects: local object storage was offline during the run, so presigned-URL retrieval returned 500. That path was verified working earlier in the same environment and is tracked as an environment note, not a bug.

1.2 Defects by severity

Severity	Count	Meaning
Critical	0	Exploitable now with direct loss of data or full account control
High	1	Directly exploitable by an unauthenticated attacker; fix before public launch
Medium	9	Meaningful weakening of a security or reliability guarantee; fix soon after launch
Low	6	Hardening, defence-in-depth or user-visible polish

1.3 Controls verified as working

These are not assumptions - each was actively attacked or exercised and held.

Control	Evidence	Test IDs
Function-level authorisation	All 7 admin-only routes rejected a student token with 403, and anonymous callers with 401.	SEC-API5-001..007
JWT handling	Malformed, wrong-secret, alg:none and expired tokens were all rejected with 401.	SEC-API2-001..005
Role integrity	A token forged with the real signing secret claiming <code>role=ADMIN</code> was still refused - role is re-read from the database, not trusted from the claim.	SEC-API2-006
Mass assignment	Passing <code>role=admin</code> at signup is rejected outright by ValidationPipe whitelisting.	SEC-API3-001
Credential hygiene	No password hash, argon2 material or token hash appears in any API response. Passwords are argon2-hashed; refresh and reset tokens are stored only as HMACs.	SEC-API3-002, IT-AUTH-003/007/013
Token lifecycle	Refresh tokens rotate, replay of a consumed token is rejected, logout revokes, and a password reset revokes every live session atomically.	E2E-009, SEC-API2-007, IT-AUTH-023

Control	Evidence	Test IDs
Reset-link safety	Reset tokens are single-use, expiry-checked, domain-separated from refresh tokens, and invalidated when a newer link is issued.	IT-AUTH-012/014/020/021
Injection resistance	Prisma parameterises all queries and DTO validation rejects non-UUID input before it reaches the ORM.	SEC-INJ-001, UT-DTO-015
Error hygiene	Malformed requests return generic bodies - no stack traces, file paths or SQL leaked.	SEC-API8-006
Header injection	Quote, backslash and CRLF characters in filenames are neutralised before entering Content-Disposition.	UT-ST0-003/004/005

2. Defect register

Every defect below was reproduced by an executed test. The 'Evidence' line names the test case that demonstrates it, so each can be re-verified after a fix.

QA-01	High	No brute-force protection on authentication	OWASP API4
Observed	25 consecutive failed logins against the admin account were all processed (~6s, zero 429s). No rate limiter is registered in AppModule, so password guessing is bounded only by network speed.		
Evidence	SEC-API4-001		
Remediation	Add @nestjs/throttler globally (e.g. 5 attempts / 15 min per IP+email on /auth/login), plus progressive backoff or temporary lockout.		

QA-02	Medium	Forgot-password timing reveals whether an account exists	OWASP API6
Observed	Registered addresses averaged 486ms vs 79ms for unregistered (6.2x; 2.5x on a second run). The registered branch performs two extra DB writes and an awaited outbound mail call. The uniform response body the code implements does not hide this.		
Evidence	SEC-API6-002, IT-AUTH-018		
Remediation	Dispatch the email without awaiting it (fire-and-forget with .catch logging), or normalise total handler time so both branches cost the same.		

QA-03	Medium	Database error on forgot-password creates a 500-vs-200 oracle	OWASP API6
Observed	The two passwordResetToken writes sit outside the try/catch that guards mail sending. A DB fault returns 500 for a registered address but a clean 200 for an unregistered one - a binary account existence signal that is more reliable than timing.		
Evidence	IT-AUTH-017		
Remediation	Wrap the whole post-lookup block in try/catch and always return the same generic 200.		

QA-04	Medium	Password-reset requests are not rate limited	OWASP API6
Observed	Six consecutive reset requests for one address were all accepted. Each consumes provider email quota (Brevo free tier is 300/day) and mails the account owner, enabling inbox flooding and trivial quota exhaustion.		
Evidence	SEC-API6-001		
Remediation	Throttle per email address and per IP (e.g. 3 per hour).		

QA-05	Medium	CORS accepts requests from any origin	OWASP API8
Observed	Access-Control-Allow-Origin returns '*'. main.ts uses NestFactory.create(AppModule, { cors: true }), so any website can call the API from a visitor's browser.		
Evidence	SEC-API8-001		
Remediation	Replace with an explicit allowlist: cors: { origin: [APP_BASE_URL], credentials: true }.		

QA-06	Medium	All standard security response headers are missing	OWASP API8
Observed	X-Content-Type-Options, X-Frame-Options, Strict-Transport-Security and Content-Security-Policy are all absent - helmet is not registered. The app is framable (clickjacking) and MIME-sniffable.		
Evidence	SEC-API8-002 . . 005		
Remediation	app.use(helmet()) in main.ts; set HSTS only behind HTTPS.		

QA-07	Medium	Oversized request body returns 500 instead of 413	OWASP API4
Observed	A 2MB JSON body produced HTTP 500. Express's PayloadTooLargeError is not an HttpException, so the global filter maps it to a generic 500 - an availability/observability problem that masks abuse.		
Evidence	SEC-API4-002		
Remediation	Set an explicit body limit and map PayloadTooLargeError to 413 in HttpExceptionFilter.		

QA-08	Medium	Unknown routes render a completely blank page	Functional
Observed	App.tsx has no catch-all <Route path="*">. React Router matches nothing, so #root stays empty - not even the header renders. Vercel's SPA rewrite serves index.html for every path, so any typo, stale bookmark or shared dead link is a white screen in production.		
Evidence	UAT-012		
Remediation	Add a catch-all route rendering a 404 page inside AppLayout.		

QA-09	Medium	Uploaded file type is trusted from the client, never sniffed	OWASP API3
Observed	Validation checks only the multipart Content-Type header. A file whose bytes are HTML but declared application/pdf is accepted, stored, and later served with response-content-type=application/pdf into an iframe. Mitigating factor: upload is admin-only today.		
Evidence	IT-RES-003		
Remediation	Verify magic bytes (e.g. %PDF-) server-side before accepting, and re-derive the stored mimeType from the sniffed type rather than the client's claim.		

QA-10	Medium	Non-ASCII filenames are not encoded in Content-Disposition	Functional
Observed	quoteFileName strips quotes/CR/LF but passes non-Latin-1 characters through raw into a header value. A paper named with Devanagari/CJK characters can make presigning throw, breaking view and download for that file permanently.		
Evidence	UT-ST0-006		
Remediation	Emit RFC 5987 filename*=UTF-8"<pct-encoded> alongside an ASCII-only filename fallback.		

QA-11	Low	Framework disclosed via X-Powered-By	OWASP API9
Observed	Responses advertise 'X-Powered-By: Express', narrowing an attacker's search for version-specific exploits.		
Evidence	SEC-API9-001		
Remediation	app.disable('x-powered-by') (helmet does this automatically).		

QA-12	Low	Document viewer title reads 'Loading...' while showing an error	Functional
Observed	The header renders {doc?.fileName ?? 'Loading...'}, which only distinguishes 'has document' from 'no document'. During an error the body shows the failure while the title bar still says Loading - confirmed live in UAT.		
Evidence	UAT-003		
Remediation	Branch the title on isLoading / error / loaded explicitly.		

QA-13	Low	Signup placeholder advertises a domain the server rejects	Functional
Observed	The email field placeholder reads 'you@youruniversity.edu.in' but the only allowlisted domain is mmcoe.edu.in. Submitting the suggested domain fails, and the error never names an accepted domain.		
Evidence	UAT-008		
Remediation	Drive the placeholder and the error message from the allowlist, e.g. 'Use your @mmcoe.edu.in address'.		

QA-14	Low	User-supplied fullName is stored without sanitisation	OWASP API3
Observed	A <script> payload in fullName is persisted verbatim. React escapes on render so there is no XSS today, but the raw value would be live for any future non-React consumer (email templates, exports, a mobile client).		
Evidence	SEC-INJ-002		
Remediation	Strip or encode control markup on write, and keep escaping on output.		

QA-15	Low	Path-traversal sequences survive into the storage object key	Functional
Observed	An upload named ../../etc/passwd.pdf yields a key containing that sequence. S3-compatible stores treat keys as opaque strings so nothing escapes the bucket today, but it breaks any consumer that maps keys onto a filesystem.		
Evidence	IT-RES-006		
Remediation	Normalise the basename before composing the key.		

QA-16	Low	Password policy enforces length only	OWASP API2
Observed	An eight-character password such as '12345678' is accepted at both signup and reset. No complexity, no breached-password check.		
Evidence	UT-DT0-006		
Remediation	Raise the floor to 10-12 characters and screen against a common-password list.		

3. Remediation roadmap

Order	Action	Addresses	Effort
1	Register @nestjs/throttler globally; tighter limits on /auth/login, /auth/signup and /auth/forgot-password	QA-01, QA-04	~1 hour
2	app.use(helmet()) and replace cors:true with an explicit origin allowlist	QA-05, QA-06, QA-11	~30 min
3	Move the mail send off the request path (fire-and-forget) and wrap the reset writes in try/catch	QA-02, QA-03	~30 min
4	Add a catch-all 404 route in App.tsx	QA-08	~20 min
5	Sniff magic bytes on upload; derive stored mimeType from the sniffed value	QA-09	~1 hour
6	RFC 5987-encode Content-Disposition filenames	QA-10	~30 min
7	Map PayloadTooLargeError to 413 in HttpExceptionFilter	QA-07	~20 min
8	Fix viewer title states; drive signup placeholder/error from the domain allowlist	QA-12, QA-13	~40 min
9	Raise password floor to 10-12 chars; sanitise fullName and storage-key basenames	QA-14, QA-15, QA-16	~1 hour

3.1 A note on scope

This engagement was described as low-risk because the audience is students. That is worth qualifying: ScholarBase stores student names, college email addresses, argon2 password hashes and password-reset tokens. Under India's DPDP Act 2023 those are personal data, and password reuse means a credential compromise here can propagate to other services. The severities above are assigned on that basis rather than on the assumption that the data is disposable.

4. Test case inventory

4.1 Unit tests (42 cases, all passed)

Scope: logic that can be exercised with no I/O. Covers JWT TTL parsing, the viewer MIME allowlist, Content-Disposition sanitisation, presigned-URL shaping, and every request DTO's validation rules.

Test case	Result
UT-MIME-001 accepts every type declared viewable	PASS
UT-MIME-002 accepts PDF, the only type papers uploads can produce	PASS
UT-MIME-003 rejects renderable-but-dangerous types	PASS
UT-MIME-004 rejects office types that cannot render in an iframe	PASS
UT-MIME-005 rejects empty/garbage input rather than throwing	PASS
UT-MIME-006 is case-sensitive and does not strip parameters (documents current behaviour)	PASS
UT-DUR-001 converts each supported unit to milliseconds	PASS
UT-DUR-002 parses the production defaults used by the app	PASS
UT-DUR-003 tolerates surrounding whitespace	PASS
UT-DUR-004 tolerates internal whitespace between amount and unit	PASS
UT-DUR-005 rejects malformed values rather than silently defaulting	PASS
UT-DUR-006 accepts zero without throwing (boundary)	PASS
UT-DTO-001 normalizes email to trimmed lowercase before validation	PASS
UT-DTO-002 rejects malformed email addresses	PASS
UT-DTO-003 enforces a minimum password length	PASS
UT-DTO-004 rejects an empty full name	PASS
UT-DTO-005 signup's password floor agrees with the shared MIN_PASSWORD_LENGTH constant	PASS
UT-DTO-006 does not enforce any password complexity (documents current policy)	PASS
UT-DTO-007 normalizes email so login is case-insensitive	PASS
UT-DTO-008 ForgotPasswordDto requires a valid email	PASS
UT-DTO-009 ResetPasswordDto rejects an empty token	PASS
UT-DTO-010 ResetPasswordDto enforces MIN_PASSWORD_LENGTH	PASS
UT-DTO-011 ForgotPasswordDto does not normalize case (asymmetry with login/signup)	PASS
UT-DTO-012 coerces a numeric query string to a number	PASS
UT-DTO-013 treats an empty query value as absent rather than 0	PASS
UT-DTO-014 rejects a non-numeric year instead of silently filtering by NaN	PASS
UT-DTO-015 rejects a non-UUID subjectId (prevents raw values reaching Prisma)	PASS
UT-DTO-016 enforces message limit boundaries 1..200	PASS
UT-DTO-017 enforces academic-year sanity bounds on upload	PASS
UT-STO-001 download URL requests an attachment disposition	PASS
UT-STO-002 view URL requests an inline disposition and pins the content type	PASS
UT-STO-003 neutralizes a double quote so the filename cannot escape the quoted string	PASS
UT-STO-004 neutralizes CR and LF so a header cannot be injected	PASS
UT-STO-005 neutralizes backslash escapes	PASS
UT-STO-006 does NOT encode non-ASCII filenames (documents known defect QA-004)	PASS
UT-STO-007 applies the documented default expiries (5 min download, 30 min view)	PASS
UT-STO-008 resolves logical bucket names through env overrides	PASS

Test case	Result
UT-SFU-001 forwards bucket and file key to the storage layer for downloads	PASS
UT-SFU-002 forwards the mime type for views (required to render inline)	PASS
UT-SFU-003 serializes expiry as an ISO string in the download DTO	PASS
UT-SFU-004 view DTO carries the metadata the viewer needs, and no storage key	PASS
UT-SFU-005 is agnostic to the record's concrete model (structural typing)	PASS

4.2 Integration tests (35 cases, all passed)

Scope: services wired against mocked Prisma, with real argon2 and real HMAC. Two cases (IT-AUTH-017/018) are characterisation tests - they pass because they successfully demonstrate defects QA-02 and QA-03.

Test case	Result
IT-RES-001 rejects a request with no file attached	PASS
IT-RES-002 rejects a non-PDF declared content type	PASS
IT-RES-003 SECURITY — accepts HTML bytes when the client declares application/pdf	PASS
IT-RES-004 refuses a byte-identical duplicate via checksum	PASS
IT-RES-005 derives a namespaced storage key with a random component	PASS
IT-RES-006 SECURITY — traversal sequences in the filename survive into the storage key	PASS
IT-RES-007 accepts the documented office formats	PASS
IT-RES-008 rejects an unsupported type for notes	PASS
IT-RES-009 papers download/view 404 when the row does not exist	PASS
IT-RES-010 notes download/view 404 when the row does not exist	PASS
IT-RES-011 each resource presigns against its own bucket	PASS
IT-AUTH-001 rejects an email outside the allowed university domains	PASS
IT-AUTH-002 rejects a duplicate account with 409 rather than overwriting	PASS
IT-AUTH-003 stores an argon2 hash, never the plaintext password	PASS
IT-AUTH-004 normalizes the email to lowercase before persisting	PASS
IT-AUTH-005 returns an identical generic error for unknown user and wrong password	PASS
IT-AUTH-006 issues tokens and never returns the password hash to the client	PASS
IT-AUTH-007 persists only an HMAC of the refresh token, never the raw value	PASS
IT-AUTH-008 rejects an expired refresh token	PASS
IT-AUTH-009 rejects an unknown/revoked refresh token	PASS
IT-AUTH-010 rotates the token — the presented one is revoked after use	PASS
IT-AUTH-011 resolves silently for an unregistered address (no enumeration via response)	PASS
IT-AUTH-012 invalidates any outstanding reset link before issuing a new one	PASS
IT-AUTH-013 stores only a hash of the reset token; the raw token goes to email only	PASS
IT-AUTH-014 reset-token hash is domain-separated from the refresh-token hash	PASS
IT-AUTH-015 honours the configured TTL when setting expiry	PASS
IT-AUTH-016 a mail delivery failure does not surface to the caller	PASS
IT-AUTH-017 SECURITY — a DB failure DOES surface, creating a 500-vs-200 enumeration oracle	PASS
IT-AUTH-018 SECURITY — the registered path performs strictly more awaited work (timing oracle)	PASS
IT-AUTH-019 rejects an unknown token	PASS
IT-AUTH-020 rejects an already-used token (single use enforced)	PASS
IT-AUTH-021 rejects an expired token	PASS
IT-AUTH-022 gives the same generic message for unknown, used and expired tokens	PASS

Test case	Result
IT-AUTH-023 on success, burns the token and revokes every live session atomically	PASS
IT-AUTH-024 the new password is argon2-hashed before it reaches the database	PASS

4.3 API E2E and OWASP security tests (57 cases)

Executed over HTTP against the running server, so global guards, pipes, filters and CORS middleware are all in the path. 'Actual' records exactly what the server returned.

ID	Test	Actual result	Res.
E2E-001	Health endpoint is public and healthy	200	PASS
E2E-002	Signup refuses a non-university email domain	400	PASS
E2E-003	Signup succeeds for an allowlisted domain and returns tokens	201, token=true	PASS
E2E-004	Duplicate signup is rejected with 409	409	PASS
E2E-005	Login with valid credentials issues tokens	200, token=true	PASS
E2E-006	Login with wrong password is rejected	401	PASS
E2E-007	GET /auth/me returns the caller's profile	200, email=qa-student-1786556921378@mmcoe.edu.in	PASS
E2E-008	GET /auth/me without a token is rejected	401	PASS
E2E-009	Refresh token rotates and the consumed token is revoked (replay blocked)	first=200, replay=401	PASS
E2E-010	Seeded admin can authenticate	200, role=admin	PASS
E2E-011	Subject catalog is publicly readable	200, n=78	PASS
E2E-012	Question paper list is publicly readable	200, n=18	PASS
E2E-013	Paper view URL is issued to anonymous users (papers are public by design)	500, keys=statusCode,message	FAIL
E2E-014	View DTO does not leak the internal storage key	statusCode,message	PASS
E2E-015	Paper download URL is issued	500	FAIL
E2E-017	Unknown paper id returns 404, not 500	404	PASS
E2E-018	Notes list is publicly readable (metadata only)	200	PASS
SEC-API5-001	Student is denied admin function: Upload question paper	403	PASS
SEC-API5-002	Student is denied admin function: Upload note	403	PASS
SEC-API5-003	Student is denied admin function: Admin study-room oversight	403	PASS
SEC-API5-004	Student is denied admin function: Create subject	403	PASS
SEC-API5-005	Student is denied admin function: Create year level	403	PASS
SEC-API5-006	Student is denied admin function: Create exam type	403	PASS
SEC-API5-007	Anonymous caller is denied the admin oversight endpoint	401	PASS
SEC-API11-001	Anonymous user cannot obtain a note view URL	no notes seeded — untested	INFO
SEC-API11-003	/auth/me is scoped to the bearer's own account (no id parameter to tamper)	id=self	PASS
SEC-API11-004	Study room listing requires authentication	auth=200, anon=401	PASS
SEC-API12-001	Rejected: No Authorization header	401	PASS
SEC-API12-002	Rejected: Malformed token string	401	PASS
SEC-API12-003	Rejected: Structurally valid JWT signed with the wrong secret	401	PASS
SEC-API12-004	Rejected: alg:none unsigned token (algorithm confusion)	401	PASS
SEC-API12-005	Rejected: Expired token	401	PASS
SEC-API12-006	Role claim tampering: token says ADMIN, database says student	403	PASS
SEC-API12-007	Logout revokes the refresh token	logout=204, refresh=401	PASS
SEC-API13-001	Mass assignment: extra 'role' field at signup cannot grant admin	400, role=n/a	PASS
SEC-API13-002	Login response contains no password hash or token hash	clean	PASS

ID	Test	Actual result	Res.
SEC-API3-003	Public paper DTO omits storage key and checksum	fields: id,subjectId,examTypeId,academicYear,fileName,fileSizeBytes,uploadStatus,ingestionStatus,createdAt	PASS
SEC-API4-001	Brute-force protection on login (25 bad attempts)	0 throttled, all 25 answered 401 in 6016ms	FAIL
SEC-API6-001	Password-reset requests are rate limited per address	6 accepted (200), 0 throttled	FAIL
SEC-API4-002	Oversized JSON body is rejected rather than processed	500	WARN
SEC-API6-002	Forgot-password timing does not reveal whether an account exists	registered 486.5ms vs unregistered 78.6ms (6.19x)	FAIL
SEC-API6-003	Forgot-password response body/status is identical for both cases	200/200, identical=true	PASS
SEC-API8-001	CORS does not reflect/allow arbitrary origins	Access-Control-Allow-Origin: *	FAIL
SEC-API8-002	Security header present: x-content-type-options	(absent)	FAIL
SEC-API8-003	Security header present: x-frame-options	(absent)	FAIL
SEC-API8-004	Security header present: strict-transport-security	(absent)	FAIL
SEC-API8-005	Security header present: content-security-policy	(absent)	FAIL
SEC-API9-001	Server does not advertise its framework via X-Powered-By	Express	FAIL
SEC-API8-006	Malformed request does not leak stack traces or internals	clean (400)	PASS
SEC-API9-002	TRACE verb is not served	not sent by client ('TRACE' HTTP method is unsupported.)	INFO
SEC-API9-003	PUT on a GET-only route is not served	404	PASS
SEC-API9-004	PATCH on a GET-only route is not served	404	PASS
SEC-API9-005	DELETE on a GET-only route is not served	404	PASS
SEC-API7-001	No user-controlled URL is fetched server-side	Brevo endpoint is a module constant	PASS
SEC-API10-001	Third-party (Brevo) response is not reflected to API clients	provider body is logged, generic error thrown	PASS
SEC-INJ-001	SQL-injection style input is rejected by validation, not passed to the ORM	400	PASS
SEC-INJ-002	Script payload in fullName is stored raw (relies on React escaping at render)	stored verbatim	WARN

4.4 User acceptance testing (14 scenarios)

Driven through a real browser against the running application - navigation, forms, modals, route guards, theming and responsive layout.

ID	Scenario	Observed	Res.
UAT-001	Anonymous landing page renders department catalogue	6 departments listed, no console errors	PASS
UAT-002	Browse Dept > Year > Semester > Subject to a paper	Subject page lists both papers with View + Download	PASS
UAT-003	Open in-app document viewer with storage unreachable	Error shown, but title bar still reads 'Loading...'	PARTIAL
UAT-004	Close viewer via Escape key	Modal closed; body scroll-lock correctly released	PASS
UAT-005	Notes tab with no notes uploaded	Correct empty state message	PASS
UAT-006	Open /reset-password with no token in URL	'Reset link missing' with recovery link	PASS
UAT-007	Anonymous user opens /admin	Redirected to /login	PASS
UAT-008	Sign up using the domain shown in the field placeholder	Rejected; error does not name an accepted domain	FAIL
UAT-009	Sign up with an allowlisted college domain	Account created, session established, redirected home	PASS
UAT-010	Logged-in student opens /admin	Redirected away; admin UI not rendered	PASS
UAT-011	Toggle dark theme and reload	Theme applied and persisted across reload	PASS
UAT-012	Navigate to an unknown URL	Entirely blank page - no 404 view, header absent	FAIL
UAT-013	Subject page at 375px mobile viewport	No horizontal overflow; tabs usable	PASS
UAT-014	Console/network hygiene on primary journeys	No console errors on home/subject/auth pages	PASS

Appendix A - Reproducing these results

The suites are committed to the repository. Unit and integration tests need no running services; the API suite needs the backend running and reads admin credentials from backend/.env. It creates throwaway accounts and deletes them on completion, so it must be pointed at a development database, never production.

Command	What it runs
<code>pnpm --filter @scholarbase/backend test</code>	77 unit + integration specs (no services required)
<code>node backend/test/e2e/api-security-suite.js</code>	57 E2E + OWASP checks against a running backend
<code>API_BASE=https://<host>/api node ../api-security-suite.js</code>	Point the same suite at a deployed environment

Appendix B - Environment and coverage limits

Limitation	Detail
Object storage offline locally	Local MinIO was not running (Docker unavailable), so E2E-013/015/016 returned 500. Presigned-URL generation was verified working earlier in the same environment; retest with storage up to close these out.
Notes corpus empty	No notes were uploaded at test time, so SEC-API1-001 (anonymous note access) could not be exercised against real data. The equivalent control was verified at the controller level - the route omits @Public() and the global JwtAuthGuard applies.
Study rooms partially covered	Room listing and admin oversight authorisation were tested. Live WebSocket signalling, WebRTC media and multi-participant presence were not - they need multiple concurrent real clients.
Frontend unit tests absent	The frontend has no test tooling installed; its behaviour was covered through UAT rather than component tests. Adding Vitest + Testing Library would let the viewer state machine and route guards be pinned down in CI.
Load and soak testing	Out of scope. Throughput, connection limits and the Neon free-tier connection ceiling under concurrent load were not measured.